SETH DAVIES-PATRICK

Cyber Threats and Human Exploitation in Healthcare SMEs

An industry threat analysis focused on small general practices and the practical steps SMEs can take to defend themselves.

I recently completed this project/assessment for my Human Factors in Cyber Security class at La Trobe University analysing how cybercriminals target small healthcare providers, why these attacks succeed so often, and what practical defences small teams can actually afford to put in place. Sharing it here in case it's useful to others working in or around healthcare IT and security.

18% of all Australian data breach notifications came from the health sector. The highest of any sector (**OAIC, 2025)**	**21+** clinics affected in the July 2026 Partnered Health breach across five states	**22 days** gap between breach detection and patient notification at Partnered Health

THE INDUSTRY

Industry Profile – HEALTHCARE SMES

Healthcare SMEs in particular small general practices, allied health clinics and specialist practices form the backbone of Australia's primary health care system, typically employing between 10 – 50 staff members across the clinical and admin roles. Unlike large hospital networks, these organisations rarely employ dedicated IT or cybersecurity staff, instead rely on general practice managers or outsourced IT providers. Digital maturity varies widely: most now operate on cloud integrated patient management system (like **Best-Practice** and **Medical-Director**) linked to Medicare systems, alongside growing use of telehealth and AI assisted administration tools. This combination of high value patient data, constant Medicare/Insurance connectivity, and limited security investment makes healthcare SMEs an attractive yet under defended target for cyber criminals.

> **Cyber Criminals succeeded in 95% of the healthcare cyber attacks they've attempted in Australia compared to just 52% across all other industries combined. This is the highest attack success rate of any sector. (Avant, 2025)**

> **The Health Sector recorded more data breach notifications than any other industry in Australia.** **(OAIC, 2025)**

> **Most clinics in Australia now run cloud connected patient management software that is linked directly to Medicare, meaning a single compromised login can expose records across an entire practices network.**

HOW IT WORKS

Cybercrime Business Models

Cybercriminals increasingly treat healthcare data as a commodity, operating through several interconnected business models:

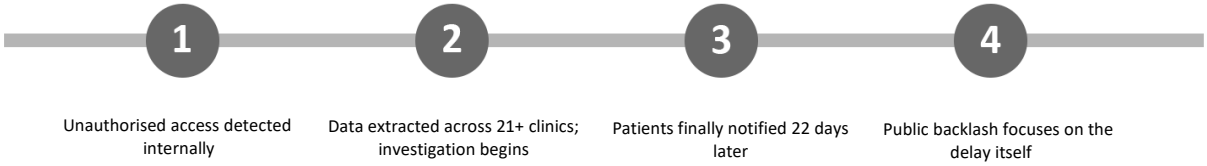
1	***Ransomware-as-a-Service (RaaS):*** RaaS has become the most dominant model, where developers lease ransomware tools to affiliates for a share of profits, lowering the technical barrier to entry. Groups such as ***INC Ransom*** have moved through Australian healthcare and professional services organisations methodically rather than opportunistically **(Hollingworth, 2026)** gaining access through compromised credentials, escalating to administrator privileges, and navigating networks laterally undetected before deploying ransomware.
2	***Double & Triple Extortion:*** Has replaced simple encryption as the primary monetisation method **(SentinelOne, 2025)**. Rather than only encrypting data for ransom, attackers now exfiltrate it first, then threaten to publish or sell it if payment is refused and in triple extortion, the attackers usually threaten patients or partner organisations directly with another threat such as a distributed denial of service attack (DDoS). **(SentinelOne, 2025)**
3	***Data Exfiltration & Resale*** This Model monetises stolen records independently of any ransomware outcome. Because Medicare numbers and medical histories cannot be cancelled or reissued like a credit card, they are your records and cannot be altered or changed, they carry higher black market value and longer term fraud potential than typical financial data. **(Flare, 2026)**

> **AI angle:** phishing is no longer a generic attack, attackers use AI to build detailed, context aware messages referencing real people within your life to make it seem more real than it actually is, making the initial credential compromise far harder for busy clinic staff to detect at first glance.

CASE STUDY

Threat Assessment & Impact Analysis | PARTNERED HEALTH

The clearest illustration of these threats is the June 2026 breach at Partnered Health, an Australian primary care network operating over 60 clinics nationwide. The organisation confirmed a malicious actor had extracted patient medical histories and Medicare data across at least 21 different clinics spanning New South Wales, Victoria, Queensland, Western Australia, and the ACT. **(Hollingworth, 2026)**



This case reflects a wider trend: healthcare ransomware and data-theft incidents rose 14% globally in the first half of 2026 compared to the previous six months, with Australia among the **most** affected countries in the world. **(Moody, 2026)**

PEOPLE	OPERATIONS	ORGANISATIONAL RESPONSIBILITY
Exposed Medicare numbers and medical histories create a long term identity fraud risk. Unlike a credit card, this sort of data cannot just be simply changed, cancelled or reissued.	Comparable incidents show the severity of what this can affect. In February 2026 an attack happened on the University of Mississippi Medical centre which forced appointment cancellations for up to 2 weeks.	Partnered Health's 22 day notification delay drew sharper criticism than the whole breach itself did **(Murray, 2026)**. Proving technical compromise is rarely the only failure in these scenarios.

THE HUMAN FACTOR

Human Factors

> **37%** Of reported Australian data breaches from JAN-JUN 2025 were caused by some sort of human error which makes it up 29% from the last period (**OAIC, 2025),** Technical defences only matter if the people around them make proper decisions under immense pressure.

1	**Time pressure & phishing susceptibility** A busy receptionist or nurse scanning their emails between patients has little time to scrutinize and thoroughly read over a message referencing a real person by name within their lives, exactly what an AI enhanced phishing email does.
2	**Credential Reuse & Shared Logins** Combined with time pressure, widespread credential reuse in smaller practices creates the entry point that attackers like those behind the Partnered Health breach really rely on.
3	**Disclosure Delay as a Human Decision** Organisations often delay disclosure out of fear it will damage their reputation as a company, but that fear is usually misplaced. Partnered Health shows this clearly, it was a 22 day gap. The delay from when it happened to when they made it public is what actually drove the strongest backlash around this breach. **(Murray, 2026)**

WHAT SMEs CAN DO

Mitigation Strategies

Addressing these risks requires a mitigation plan and process that matches how the attack chain unfolds. From initial credential compromise through to organisational response.

Category	Strategy	Why it Matters
Technical	Multi-factor Authentication (MFA) on all clinical software logins possible.	Directly counters the credential based access used against Partnered Health, stolen passwords become far less useful when MFA is in use.
Technical	Isolated offline backups.	Limits ransomware damage by allowing restoration without paying a ransom for the data back.
Technical	Vendor security checks.	Closes a gap that OAIC case studies show is frequently exploited when third party security is assumed rather than verified **(OAIC, 2025)**
Human	Role specific phishing simulations run during realistic workloads.	Better prepares receptionists and clinic staff to recognise AI Enhanced, context aware phishing attempts.
Human	Credential hygiene policy (unique logins, password managers).	Directly reduces the shared login risk that is identified in Section D
Organisational	Documented incident response plan with defined notification timeliness.	Removes the reputational loss hesitation that drove Partnered Health's 22 day delay.
Organisational	Cyber Insurance	Offsets recovery costs but shouldn't ever be used as the primary defence.
AI (Defence)	AI Assisted email filtering & anomaly detection.	Offers genuine defensive value, provided staff are trained to recognise AI generated threats rather than relying on tools alone.

APA7

REFERENCES

1. Avant. (2025, November 25). *Cybersecurity guide for general practices*. https://avant.org.au/resources/healthcare-cybersecurity-a-comprehensive-guide-for-accredited-general-practices
2. Flare. (2026, June 17). *Stolen medical records fuel a black market of fraud, identity theft, and patient harm*. https://flare.io/learn/resources/blog/stolen-medical-records-fuel-black-market-fraud-identity-theft-patient-harm
3. Healthcare Dive. (2026, March 2). *University of Mississippi Medical Centre reopens clinics after ransomware attack*. https://www.healthcaredive.com/news/university-of-mississippi-medical-center-ransomware-attack/812823/
4. Hollingworth, D. (2026a, July 15). *Partnered Health confirms dozens of clinics potentially compromised by cyber attack*. Cyber Daily. https://www.cyberdaily.au/security/13908-partnered-health-confirms-dozens-of-clinics-potentially-compromised-by-cyber-attack
5. Hollingworth, D. (2026b, August 3). *Exclusive: Partnered Health responds to INC Ransom data breach claims*. Cyber Daily. https://www.cyberdaily.au/security/13986-exclusive-partnered-health-responds-to-inc-ransom-data-breach-claims
6. Moody, R. (2026, July 9). *Healthcare ransomware roundup: H1 2026 stats on attacks, ransoms, and data breaches*. Comparitech. https://www.comparitech.com/news/healthcare-ransomware-roundup-h1-2026-stats-on-attacks-ransoms-and-data-breaches/
7. Murray, W. (2026, July 16). *Delay in revealing Partnered Health breach and stolen patient data 'unacceptable'*. ABC News. https://www.abc.net.au/news/2026-07-16/medical-records-hack-delay/106924070
8. Office of the Australian Information Commissioner. (2025, November 4). *Latest notifiable data breach statistics for January to June 2025* [Blog post]. https://www.oaic.gov.au/news/blog/latest-notifiable-data-breach-statistics-for-january-to-june-2025
9. Sapphire. (2026, July 31). *Update: Partnered Health — recent cyber incident*. Partnered Health. https://partneredhealth.com.au/partnered-health-recent-cyber-incident/
10. SentinelOne. (2025, December 19). *What is triple extortion ransomware? Defending your organization*. https://www.sentinelone.com/cybersecurity-101/threat-intelligence/what-is-triple-extortion/

About this project

This analysis was produced as part of my Bachelor of Information Technology studies at La Trobe University, focused on cybersecurity and human factors. I'm currently exploring roles in cybersecurity, systems administration, and software engineering, and always keen to connect with others in the field.
- *Seth Davies-Patrick*